

Hybrid and private access: VPN, Direct Connect, MACsec, Verified Access

Getting traffic in from outside – and the encryption assumption that catches almost everybody.

Private is not encrypted. A Direct Connect link is dedicated, and by default it is plaintext.

Site-to-Site VPN

- ◆ **IPsec over the public internet.** Encrypted by design, and subject to whatever the internet is doing that day.
- ◆ Each connection gives you **two tunnels in different Availability Zones**, for redundancy. Use both.
- ◆ Terminates on a **virtual private gateway** for one VPC, or a **Transit Gateway** for many.
- ◆ **Accelerated Site-to-Site VPN** routes over the AWS global network via Global Accelerator, reducing the internet portion.
- ◆ Authentication by pre-shared key or by **certificate from AWS Private CA**, which is the better answer where key rotation matters.

ON THE EXAM

VPN is the answer whenever a requirement says encrypted in transit and does not say anything about bandwidth or latency.

Client VPN

- ◆ For **people**, not sites. OpenVPN-based and managed.
- ◆ Authentication by **mutual certificate**, **Active Directory**, or **SAML federation**.
- ◆ **Authorization rules** grant network access per AD or SAML group.
- ◆ **Split tunnel** sends only VPC-bound traffic through the tunnel.
- ◆ It grants **network** access. Once connected, the user is on the network.

ON THE EXAM

A VPN answers 'may you join the network', not 'may you use this application'.

Direct Connect, and the encryption gap

- ◆ A dedicated Ethernet connection from your router to an AWS Direct Connect location. Consistent latency, high bandwidth.
- ◆ **Private VIF** to a VPC. **Public VIF** to AWS public endpoints. **Transit VIF** to a Transit Gateway.
- ◆ **None of those virtual interfaces encrypts anything.** A private VIF is private, and it is plaintext.
- ◆ **Dedicated** connections are 1, 10, 100 or 400 Gbps. **Hosted** connections come from a partner at smaller sizes.
- ◆ Two ways to encrypt it: **IPsec VPN over Direct Connect**, or **MACsec** – and they are not interchangeable.

ON THE EXAM

The classic design is a VPN over a public VIF, or over a transit VIF to a Transit Gateway. You get the private path and the encryption.

MACsec, and exactly what it covers

- ◆ **IEEE 802.1AE**, layer 2 encryption at near line rate. Confidentiality, integrity, origin authenticity, replay protection.
- ◆ **Dedicated only, 10/100/400 Gbps, selected locations.** Never 1 Gbps, never hosted.
- ◆ Needs **direct layer 2 adjacency**. Your device must support MACsec; last-mile must pass layer 2.
- ◆ You supply a **CKN and CAK pair**; devices derive the secret key. Stored in Secrets Manager.
- ◆ **It encrypts the cross-connect only** – your router to the Direct Connect device.

ON THE EXAM

AWS is explicit: MACsec is a layer you add, not a layer you swap in.

IPsec VPN over Direct Connect, or MACsec?

VPN OVER DIRECT CONNECT

Encrypts the session

- Works on any connection, any speed
- Protects into the VPC, not just the hop
- IPsec overhead reduces throughput
- No special hardware needed

MACSEC

Encrypts the link

- Near line rate, negligible overhead
- Dedicated 10/100/400 Gbps only
- Selected locations, layer 2 adjacency
- Covers the cross-connect only

THE TIEBREAKER

Constraints usually decide this. A hosted or 1 Gbps connection rules MACsec out entirely, whatever the throughput requirement.

Transit Gateway as a security boundary

- ◆ A regional hub for VPCs, VPNs and Direct Connect. One attachment each, instead of a peering mesh.
- ◆ **Multiple route tables** are the security feature. Prod and dev share a gateway and cannot reach each other.
- ◆ Route every VPC through an **inspection VPC** for centralised Network Firewall.
- ◆ **Transit Gateway Flow Logs** record what crossed. Peering has no equivalent.
- ◆ Attaching a VPC grants no reachability by itself. Route tables must agree.

ON THE EXAM

Segmentation by route table: separate networks sharing one gateway.

AWS Verified Access

- ◆ Application access **without a VPN**. Users reach specific applications; they never join the network.
- ◆ **Trust providers** supply context: user identity from IAM Identity Center or an OIDC provider, and device posture from a third-party device service.
- ◆ Policies are written in **Cedar**, evaluated per request, combining user, group and device signals.
- ◆ **Every access attempt is logged** with the user context the trust providers supplied, which is how you refine a policy.
- ◆ You can attach a **WAF web ACL** to a Verified Access instance, as noted in module 12.

ON THE EXAM

The difference from Client VPN in one line: a VPN answers 'may you join the network', Verified Access answers 'may you open this application, right now, from this device'.

Proving what can reach what

- ◆ **Network Access Analyzer** defines a **network access scope** and finds every path that violates it.
- ◆ It reasons over configuration across accounts and VPCs – proving a path is absent without sending a packet.
- ◆ **Inspector network reachability findings** do the same per instance, with no agent.
- ◆ **Both are named in skill 3.3.5. SCS-C03 removed** VPC Reachability Analyzer.
- ◆ It analyses configuration, not traffic. Possible versus happened.

ON THE EXAM

Flow logs prove nobody used the path. This proves the path does not exist.

A healthcare provider sends patient records to AWS over a 1 Gbps hosted Direct Connect connection using a private virtual interface. An auditor requires documented evidence that the data is encrypted in transit between the data centre and AWS.

The network team's response is that Direct Connect is a private, dedicated circuit that does not traverse the public internet, so encryption is unnecessary. The auditor rejects this.

What should the provider implement?

- ☐ A Enable MACsec on the Direct Connect connection
- ☐ B Nothing; the network team is correct that a private VIF is encrypted by AWS
- ☐ C Move to a public VIF, which uses TLS to AWS public endpoints
- ☐ D Run an IPsec Site-to-Site VPN over the Direct Connect connection

◆ PAUSE AND DECIDE

What should the provider implement?

A Enable MACsec

The strongest distractor, and it is impossible here. MACsec needs a dedicated connection at 10, 100 or 400 Gbps. This is a 1 Gbps hosted connection - excluded twice over.

C Public VIF with TLS

Whether TLS applies depends on the application, not the VIF type. A public VIF also changes what you can reach, and does not address the private VIF traffic.

B Nothing; a private VIF is encrypted

The misconception the whole module is built on. Private means not traversing the internet. It says nothing about encryption, and the frames are plaintext.

D IPsec VPN over the Direct Connect connection

Correct. It works on any connection at any speed, needs no special hardware, and gives the auditor a documented encryption boundary.

THE SIGNAL

Two details in the first sentence rule out MACsec: 1 Gbps, and hosted. Scenario specifications are rarely decorative.

A media company moves 40 TB a day to AWS over a 100 Gbps dedicated Direct Connect connection at a location that supports MACsec. Its own edge router supports MACsec, and there is no last-mile provider in the path.

A new policy requires all data leaving the data centre to be encrypted. Testing shows that IPsec encapsulation reduces achievable throughput below what the transfer window allows.

What should the company implement, and what should it document as the limitation?

- ☐ A Accept the IPsec throughput loss and extend the transfer window
- ☐ B Enable MACsec, documenting that it protects the cross-connect rather than end to end into the VPC
- ☐ C Enable MACsec, documenting that it provides end-to-end encryption from data centre to VPC
- ☐ D Use an accelerated Site-to-Site VPN to recover the lost throughput

◆ PAUSE AND DECIDE

What should the company implement, and what should it document as the limitation?

A Accept the throughput loss

A legitimate trade-off in some situations. Here every MACsec prerequisite is satisfied, so accepting a throughput penalty you do not have to take is the wrong engineering call.

C MACsec, documented as end to end

Right control, false documentation. MACsec secures your router to the AWS Direct Connect device. Claiming end-to-end coverage misleads the next auditor.

B MACsec, documented as protecting the cross-connect

Correct. Every prerequisite is met, it runs at near line rate, and the documented scope is accurate - encryption ends at the Direct Connect device.

D Accelerated Site-to-Site VPN

Acceleration routes the public internet portion onto the AWS network. There is no internet portion here, and it is still IPsec, so the overhead remains.

THE SIGNAL

Options B and C choose the same control and differ only in what you write down. On a security exam, that difference is the question.

A consultancy gives 400 contractors access to three internal web applications. Today they connect by Client VPN, which places them on the corporate network. A recent incident saw a contractor's compromised laptop used to scan internal subnets far beyond those applications.

The security team wants contractors to reach only those three applications, with access decisions taking account of the device's patch level and disk encryption status, checked on every request.

What should the consultancy implement?

- ☐ A Client VPN with authorization rules restricting each group to specific subnets
- ☐ B A bastion host in a public subnet with Session Manager for access
- ☐ C AWS Verified Access with identity and device trust providers, and Cedar policies per application
- ☐ D Amazon Verified Permissions to authorise each request inside the applications

◆ PAUSE AND DECIDE

What should the consultancy implement?

A Client VPN with authorization rules

A real improvement over today and still network access. The contractor is on a network, subnet-scoped, and nothing evaluates device posture per request.

C Verified Access with identity and device trust providers

Correct. Users reach applications rather than networks, and Cedar policies evaluate user and device signals on every single request.

B Bastion host with Session Manager

A pattern for administrative shell access to instances, not for 400 contractors using three web applications. It would make the lateral movement problem worse.

D Verified Permissions inside the applications

Authorises actions within an application the user has already reached. It does nothing about network reachability, and it needs the applications rewritten.

THE SIGNAL

'Used to scan internal subnets' is the tell. That is only possible because a VPN put the laptop on the network.

A bank must give its regulator documented assurance that no path exists from the internet to the subnets holding its card data, across 60 accounts, 90 VPCs, several Transit Gateways and hundreds of peering connections.

The security team has six months of VPC Flow Logs showing no inbound connections to those subnets, which the regulator has said is not sufficient evidence.

What should the bank use?

- ☐ A Network Access Analyzer with a network access scope asserting no internet path to those subnets
- ☐ B Extend VPC Flow Log retention to three years to strengthen the evidence
- ☐ C An AWS Config rule checking that the subnets have no route to an internet gateway
- ☐ D GuardDuty findings showing no unauthorised access attempts to those subnets

◆ PAUSE AND DECIDE

What should the bank use?

- A

 Network Access Analyzer with a network access scope
Correct. It reasons over configuration across accounts and VPCs to prove no path exists, which is a stronger claim than 'nobody used one'.
- B

 Three years of flow logs
More of the evidence the regulator already rejected. Absence of observed traffic never proves absence of a path - it may simply mean nobody has tried yet.
- C

 Config rule for no internet gateway route
Checks one hop of a path that may run through a peering connection, a Transit Gateway, or a NAT in another VPC. Necessary, and nowhere near sufficient.
- D

 GuardDuty findings showing no attempts
Also absence of observation, and GuardDuty reports behaviour rather than reachability. It would not know about an unused path either.

THE SIGNAL

The regulator wants proof a path cannot exist. Only configuration reasoning gives that; observation gives the weaker claim.

Five things to carry forward

- ◆ **Private is not encrypted.** No Direct Connect virtual interface encrypts anything.
- ◆ **MACsec: dedicated only, 10/100/400 Gbps, selected locations.** Never on 1 Gbps or hosted connections.
- ◆ **MACsec covers the cross-connect, not end to end.** Documenting it otherwise is its own failure.
- ◆ **A VPN grants network access. Verified Access grants application access,** per request, with device signals.
- ◆ **Flow logs prove nobody used a path. Network Access Analyzer proves the path does not exist.**

ON THE EXAM

Next: hardening compute – AMLs, EC2 Image Builder, instance roles, IMDSv2 and Session Manager.